Software Engineering Intelligence Platform

Draft Security Test Plan

Authentication • API • Mobile • AI / RAG
Security Track — Offensive Security / Penetration Testing
Version 1.0 | Draft

1. Objective

Define a structured, repeatable approach for identifying, validating and documenting security weaknesses across the implemented platform, and verify that security controls identified during threat modeling are enforced.

2. Scope

Category	Included Scope
Authentication & Authorization	Login, registration, JWT, refresh tokens, password reset, roles, tenant isolation and sessions.
API Security	ASP.NET APIs, endpoint authorization, IDOR/BOLA, mass assignment, input validation, rate limiting, webhooks and API errors.
Mobile Security	Flutter client, token/storage security, transport security, deep links, client-side controls and sensitive data exposure.
AI / RAG Security	Prompt injection, indirect injection, retrieval authorization, tenant isolation, data leakage, output validation and external-model boundary.
Supporting Controls	Secrets, logging/auditability, dependencies, configuration, queues/background jobs and security middleware where relevant.

3. Security Test Categories

ID	Category	Purpose	Priority
AUTH-01	Authentication	Login, passwords, JWT, refresh tokens, recovery and sessions.	Critical / High
AUTH-02	Authorization	RBAC, function-level access and tenant	Critical / High

		isolation.	
API-01	API Authentication	Missing, invalid, expired and altered credentials.	Critical / High
API-02	API Authorization	BOLA/IDOR, privilege escalation and tenant boundary bypass.	Critical / High
API-03	Input & Business Logic	Injection, mass assignment, parameter tampering and workflow abuse.	High / Medium
API-04	Webhooks & Integrations	Signature verification, replay, payload tampering, SSRF and OAuth scope.	Critical / High
API-05	Availability & Abuse	Rate limits, request sizes and expensive operations.	Medium / High
MOB-01	Data Storage	Tokens, cached data, logs and sensitive local information.	High / Medium
MOB-02	Transport Security	TLS validation and authorized interception resistance.	High / Medium
MOB-03	Client-Side Controls	Direct invocation and bypass of client-only restrictions.	High
AI-01	Direct Prompt Injection	Attempts to override system instructions and security constraints.	Critical / High
AI-02	Indirect Prompt Injection	Poisoned repository/document content entering the RAG pipeline.	Critical / High
AI-03	RAG Authorization	Tenant/role/permission checks before retrieval and model use.	Critical
AI-04	Data Leakage / DLP	Unauthorized data in prompts, chunks, metadata or responses.	Critical / High
AI-05	Output Validation	Sanitization and validation of model output.	High
AI-06	AI Abuse & Cost	Context limits, inference limits and expensive-request controls.	Medium / High

4. Detailed Test Areas

Authentication & Authorization

- Invalid credentials, account enumeration, brute-force resistance and rate limiting.
- Password storage and reset-token security.
- JWT signature, issuer/audience, expiry, algorithm and claim integrity.
- Refresh-token rotation, revocation and reuse detection.
- RBAC, function-level authorization and direct API invocation.
- Cross-tenant access attempts and tenant-context integrity.

API Security

- Endpoint authentication coverage.
- BOLA/IDOR and privilege escalation.
- Input validation, parameter tampering and mass assignment.
- Injection testing appropriate to implemented stores.
- Webhook signature verification and replay protection.
- SSRF testing for server-side URL processing.
- Rate limiting, request-size limits and safe resource-exhaustion tests.
- Secure error handling without secrets or internal details.

Mobile Security

- Local storage, cache, database and log inspection.
- Token protection and sensitive-data exposure checks.
- TLS/certificate validation in the authorized environment.
- Direct invocation of protected functionality.
- Deep links and external intents where applicable.
- Release-build checks for debug settings and verbose logging.

AI / RAG Security

- Direct prompt injection.
- Indirect prompt injection through ingested repository/document content.
- Tenant/role authorization before retrieval, orchestration and response delivery.
- Cross-tenant probing and unauthorized information requests.
- Sensitive-data leakage from chunks, answers, citations and metadata.
- Message-role and delimiter separation.
- Output validation and sanitization.
- External-model boundary and outbound data protection.
- Oversized prompts, unbounded context and expensive-inference abuse controls.

5. Test Case Structure

Each test case should contain: Test ID, Category, Objective, Preconditions, Steps, Expected Result, Actual Result, Evidence, Severity, Status, and Related Threat Dragon ID / Risk Register entry.

6. Test Execution Workflow

1. Environment Preparation → 2. Reconnaissance → 3. Baseline Testing → 4. Security Testing → 5. Evidence Collection → 6. Validation → 7. Remediation → 8. Retest → 9. Reporting.

7. Traceability

This plan does not recreate the existing Threat Dragon model. It converts the existing threats into executable validation activities. Each test case should reference the relevant Threat Dragon number and Risk Register row.

8. Entry & Exit Criteria

Entry: authorized environment, test accounts/roles/tenants, deployable API/mobile/AI flows, Threat Model and Risk Register v1. Exit: planned tests executed or blocked, confirmed findings evidenced, Critical/High findings addressed or documented, fixes retested, residual risks reported.

9. Initial Test Matrix

AUTH — Authentication & Authorization — JWT, refresh, reset, RBAC, tenant isolation — Planned.
API — API Security — BOLA/IDOR, validation, mass assignment, webhooks, SSRF — Planned.
MOB — Mobile Security — storage, transport, client enforcement, debug exposure — Planned.
AI — AI/RAG Security — prompt injection, retrieval ACL, DLP, output validation — Planned.
SUP — Supporting Controls — secrets, logs, queues, dependencies, configuration — Planned.

10. Deliverables

Security Test Plan v1; test cases/checklists for Authentication, API, Mobile and AI/RAG; sanitized evidence; Security Findings Report; retest results; updated Risk Register.